

DPDP COMPLIANCE AUDIT

finance-data-processing

Digital Personal Data Protection Act 2023



Grade A — Strong

Scanned: 08 April 2026

Files indexed: 14

Languages: express, node.js, postgresql, bcryptjs, jsonwebtoken, express-validator

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

The application collects user names, email addresses, and passwords, as well as financial record details. The primary DPDP risk lies in the storage and handling of user credentials (passwords) and sensitive financial transaction data.

Total findings: 13

HIGH: 1

MEDIUM: 2

INFO: 4

PASS: 4

Tech Stack: express, node.js, postgresql, bcryptjs, jsonwebtoken

Risk Profile: The application collects user names, email addresses, and passwords, as well as financial record details. The primary DPDP risk lies in the storage and handling of user credentials (passwords) and sensitive financial transaction data.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	18/18 (100%)	PASS
Section 8	10	7.0/10 (70%)	WARN
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	4.0/8 (50%)	WARN
Section 8(6)	8	6.8/8 (85%)	PASS
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	4/4 (100%)	PASS
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal		0/4 (0%)	FAIL

Estimated Total Remediation Effort: 1.1–4.2 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Application Logs

PII fields: password, email, address

users.js → userController.js → database.js

Flow 2: Application Logs

PII fields: password, email

auth.js → authController.js → database.js

Rule	Section	Severity	File
GRIEVANCE_OFFICER_MISSING	Section 13 — Grievance Redressal	HIGH	N/A
AUDIT_TRAIL_PARTIAL	Section 8(4) — Audit Trail	MEDIUM	N/A
INCOMPLETE_DELETION_COVERAGE	Section 8 — Data Principal Rights	MEDIUM	N/A
NO_BREACH_ALERTING	Section 8(6) — Breach	LOW	N/A
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	src/routes/users.js
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
NO_CROSS_BORDER_DETECTED	Section 16 — Cross-Border Transfer	INFO	N/A
CONSENT_PRESENT	Section 6 — Consent	PASS	src/routes/auth.js
CONSENT_WITHDRAWAL_PRESENT	Section 6(6) — Consent Withdrawal	PASS	src/controllers/auth Controller.js
DELETION_MECHANISM_PRESENT	Section 8 — Data Principal Rights	PASS	src/routes/records.js
DATA_ACCESS_PRESENT	Section 11 — Right to Access	PASS	src/routes/auth.js

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (1–4 hours)

Fix immediately — these represent the highest legal exposure.

- Grievance Officer Missing (1–4 hrs)

Week 2 — High Priority (4–16 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Audit Trail Partial (2–8 hrs)
- Incomplete Deletion Coverage (2–8 hrs)

Week 4 — Advisory (4–14 hours)

Address before next compliance review.

- No Breach Alerting (2–6 hrs)
- Data Portability Missing (2–8 hrs)

Total estimated remediation effort: 9–34 hours (1.1–4.2 engineering days)

Changes Since 2026-04-08

— 13 finding(s) unchanged

Details

Finding 1 of 13

[Section 13 — Grievance Redressal]

1. [HIGH] GRIEVANCE_OFFICER_MISSING — N / A

Estimated fix time: 1–4 hours

No compliant Grievance Officer / DPO publication found. A PASS requires grievance-related text or a dedicated route **and** a contact email or dedicated grievance/DPO URL. Tiny repos without a grievance route are not marked PASS.

Risk:

The absence of a designated Grievance Officer means individuals have no clear channel to raise concerns or complaints regarding their personal data, potentially leading to unresolved issues and a lack of accountability.

Fix:

1. Create a new route (e.g., '/grievance') that clearly outlines the process for lodging a grievance.
2. In the new grievance route or a dedicated 'Contact Us' page, display the contact details (email address) of the designated Grievance Officer.
3. Ensure the Grievance Officer's contact information is easily accessible to data subjects, for example, by linking to it from the privacy policy or a footer.
4. Implement a system to log and track incoming grievances to ensure they are addressed.

DPDP:

Section 13 — Grievance Redressal — requires the appointment and publication of a Grievance Officer to handle data subject complaints.

Example:

```
const express = require('express'); const router = express.Router(); router.get('/grievance', (req, res) => { res.json({ message: 'For any grievances regarding your personal data, please contact our Grievance Officer at grievance.officer@example.com.' }); }); module.exports = router;
```

Finding 2 of 13

[Section 8(4) — Audit Trail]

2. [MEDIUM] AUDIT_TRAIL_PARTIAL — N / A**Estimated fix time:** 2–8 hours

Partial audit trail detected. Found: change tracking. Missing: access logging, audit model.

Risk:

The lack of comprehensive audit trails, specifically for access logging and a defined audit model, hinders the ability to monitor data access, detect unauthorized activities, and investigate potential data breaches effectively.

Fix:

1. Implement middleware to log all incoming requests, capturing details such as timestamp, user ID (if authenticated), IP address, and requested endpoint.
2. Define a database schema or data structure for storing audit logs, including fields for event type, user, timestamp, and relevant data.
3. Integrate the audit logging middleware into all relevant routes to ensure comprehensive recording of access events.
4. Establish a retention policy for audit logs in accordance with regulatory requirements.

DPDP:

Section 8(4) — Audit Trail — mandates the maintenance of an audit trail to record and examine all activities related to the processing of personal data.

Example:

```
const express = require('express'); const router = express.Router(); const auditLog =
require('../middleware/auditLog'); // Assume this middleware exists router.get('/users/:id',
authenticate, authorize(['admin']), auditLog, (req, res) => { // ... logic to fetch user data
res.send('User data'); }); router.post('/users', authenticate, authorize(['admin']), auditLog,
(req, res) => { // ... logic to create user res.status(201).send('User created'); });
module.exports = router;
```

Finding 3 of 13

[Section 8 — Data Principal Rights]

3. [MEDIUM] INCOMPLETE_DELETION_COVERAGE — N / A**Estimated fix time:** 2–8 hours

Deletion mechanism detected but may not cover all PII storage. Uncovered files: src/config/database.js. DPDP Section 8 requires complete erasure of all personal data across all systems when a user requests deletion.

Risk:

Incomplete deletion coverage means that personal data may persist in the system even after a deletion request, violating data subject rights and potentially leading to non-compliance with data minimization principles.

Fix:

1. Identify all locations where personal data is stored, including databases, file systems, and any third-party services.
2. Develop a centralized data deletion service or function that can be called to remove a data principal's information from all identified storage locations.
3. Update existing data deletion processes to ensure they invoke the centralized deletion service for comprehensive data removal.
4. Implement a mechanism to confirm that data has been successfully deleted from all relevant systems.

DPDP:

Section 8 — Data Principal Rights — requires organizations to erase personal data upon request, ensuring complete removal across all systems.

Example:

```
// Example: In a user service async function deleteUser(userId) { await db.users.delete({ id:
userId }); // Delete from primary DB await fileStorage.deleteUserFiles(userId); // Delete
associated files await thirdPartyService.removeUser(userId); // Remove from external services
console.log(`User ${userId} deleted from all systems.`); }
```

Finding 4 of 13

[Section 8(6) — Breach]

4. [LOW] NO_BREACH_ALERTING — N / A**Estimated fix time:** 2–6 hours

Structured logging detected but no breach notification mechanism found. DPDP Section 8(6) requires notifying affected individuals and the Authority without undue delay when a breach occurs. Logging alone is insufficient — implement automated alerting (Sentry, PagerDuty, or equivalent) with escalation to a compliance team.

Risk:

The absence of a data breach notification and response mechanism means the organization is unprepared to handle security incidents, potentially delaying critical notifications to authorities and affected individuals, and exacerbating the impact of a breach.

Fix:

1. Develop a formal Data Breach Response Plan outlining steps to be taken in the event of a breach.
2. Establish clear procedures for identifying, assessing, and containing data breaches.
3. Define communication protocols for notifying the relevant supervisory authority and affected data subjects within the mandated timelines.
4. Implement technical controls and monitoring to detect potential data breaches early.

DPDP:

Section 11 — Data Breach Notification — mandates timely notification to the supervisory authority and data subjects in the event of a personal data breach.

Example:

```
// Example: Placeholder for breach response logic function handleDataBreach(breachDetails) {  
  console.error('Data breach detected:', breachDetails); // 1. Assess the breach scope and  
  impact // 2. Contain the breach // 3. Notify supervisory authority (within 72 hours if  
  required) // 4. Notify affected data subjects // 5. Document the incident and remediation  
  steps }
```

Finding 5 of 13

[Section 11 — Data Portability]

5. [LOW] DATA_PORTABILITY_MISSING — N / A**Estimated fix time:** 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Risk:

Failure to provide a data portability endpoint violates DPDP Section 11, preventing users from accessing their personal data in a usable format and hindering their rights.

Fix:

1. Implement a new Express.js route (e.g., `/api/data-portability`) that requires user authentication.
2. In the controller for this new route, fetch the authenticated user's personal data from the database.
3. Format the retrieved data into a common, machine-readable format such as JSON or CSV.
4. Return the formatted data as a file download or a JSON response, ensuring appropriate Content-Type headers are set.

DPDP:

Section 11(1) — Data Fiduciaries shall provide Data Principals with their personal data in a structured, commonly used and machine-readable format.

Example:

```
const express = require('express'); const router = express.Router(); const { authenticate } =
require('../middleware/auth'); // Assuming you have this middleware const userDataService =
require('../services/userDataService'); // Assume this service fetches user data
router.get('/export', authenticate, async (req, res) => { try { const userId = req.user.id; //
Get user ID from authenticated request const userData = await
userDataService.exportUserData(userId); res.setHeader('Content-Type', 'application/json');
res.setHeader('Content-Disposition', 'attachment; filename="user_data.json");
res.status(200).send(JSON.stringify(userData, null, 2)); } catch (error) {
res.status(500).json({ message: 'Failed to export data', error: error.message }); } });
module.exports = router;
```

Finding 6 of 13

[Section 7 — Legitimate Use]

6. [INFO] INTERNAL_ROUTE_PII_ACCESS — src / routes / users.js

Internal file (users.js) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 7 of 13

[Section 5 — Notice]

7. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 8 of 13

[Section 5 — Purpose Limitation]

8. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 9 of 13

[Section 16 — Cross-Border Transfer]

9. [INFO] NO_CROSS_BORDER_DETECTED — N / A

No foreign cloud or non-India region config detected.

Finding 10 of 13

[Section 6 — Consent]

10. [PASS] CONSENT_PRESENT — src / routes / auth.js

Framework auth/consent middleware detected in this file.

Finding 11 of 13

[Section 6(6) — Consent Withdrawal]

11. [PASS] CONSENT_WITHDRAWAL_PRESENT — src / controllers / authController.js

Consent withdrawal mechanism detected. Found in: src/controllers/authController.js (line 74)

Finding 12 of 13

[Section 8 — Data Principal Rights]

12. [PASS] DELETION_MECHANISM_PRESENT — src / routes / records.js

Data deletion mechanism detected. Found 2 deletion endpoint(s) and 7 deletion signal(s). Note: Verify deletion cascades to all PII tables (sessions, logs, related records).

Fix:

1. Verify deletion cascades to: sessions, audit_logs, third-party sync records.
2. Use database CASCADE DELETE or explicit multi-table deletion in deletion service.
3. Test deletion completeness: create account, delete, query all PII tables for orphaned data.

Finding 13 of 13

[Section 11 — Right to Access]

13. [PASS] DATA_ACCESS_PRESENT — src / routes / auth.js

Data access endpoint detected for authenticated users.

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] No user data download endpoint

Confidence: 60%

Section 8 Right to Access

The data_flows indicate that user details are retrieved (GET /api/auth/me) and financial records are retrieved (GET /api/records, GET /api/records/{id}), but there is no explicit endpoint or mechanism described for users to download all their personal data in a portable format.

Recommendation: Implement a new API endpoint, e.g., GET /api/user/data, that aggregates all personal data associated with the authenticated user and returns it in a structured format (e.g., JSON).

[AI-INFERRED] No age verification for registration

Confidence: 35%

Section 9 Children

The data_flows and pii_storage_locations show user registration collects name and email (POST /api/auth/register, POST /api/users). There is no mention or evidence of age verification before account creation, which is a requirement if the service is accessible to children.

Recommendation: Modify the user registration process (POST /api/auth/register) to include an age field and implement validation to ensure users are above the age of consent or implement parental consent mechanisms if applicable.

[AI-INFERRED] Incomplete audit trail for data access

Confidence: 50%

Section 8(4) Audit Trail

The rule engine output indicates 'AUDIT_TRAIL_PARTIAL'. While some audit trail functionality might exist, the provided context does not explicitly show logging for all personal data access events, particularly for sensitive financial data retrieval endpoints like GET /api/records/{id} or GET /api/dashboard/summary.

Recommendation: Enhance logging middleware or controllers to ensure that all retrieval operations of personal data (user details, financial records) are logged, including the user performing the action and the data accessed.